

ENCUESTA INTEGRAL DE EVALUACIÓN DE CIBERSEGURIDAD

Basada en MAGERIT v3, ENS (RD 311/2022) y Directiva NIS2

Versión: 2.0 | **Fecha:** Enero 2026 | **Clasificación:** Profesional / Confidencial

Duración estimada: 45-60 minutos | **Respondentes:** CISO/Responsable Seguridad + Equipo TI

INSTRUCCIONES PRELIMINARES

Para completar esta encuesta correctamente:

1. Responda honestamente: Los datos servirán para diagnóstico real, no auditoría punitiva.
2. Consulte internamente: Implice al menos 2 personas (seguridad + operaciones).
3. Sección por sección: No salte áreas. Cada pregunta suma información diagnóstica.
4. Escala Likert:
 - 1 = No existe / Ad hoc (inexistente, sin documentación, reactividad)
 - 2 = Iniciado / Básico (documentado pero inconsistente, aplicación parcial)
 - 3 = Establecido / Repetible (procedimientos formales, aplicación consistente)
 - 4 = Gestionado / Optimizable (medido, monitoreado, mejora continua iniciada)
 - 5 = Optimizado / Adaptativo (automatizado, predicción, anticipativo, benchmarking)
10. Comentarios: Añada contexto en secciones "Observaciones" (brevedad: 1-2 líneas).

5 = Optimizado / Adaptativo (automatizado, predicción, anticipativo, benchmarking)

Comentarios: Añada contexto en secciones "Observaciones" (brevedad: 1-2 líneas).

BLOQUE 1: GOBERNANZA Y ESTRATEGIA CIBERSEGURIDAD

1.1 Políticas y Marco Regulatorio

P1.1.1 ¿Existe una política de ciberseguridad formalizada, documentada y aprobada por la Dirección?

- ☐ 1: No existe
- ☐ 2: En borrador / Ad hoc
- ☐ 3: Formalizada, revisada anualmente
- ☐ 4: Formalizada, revisada 2×/año, alineada NIS2/ENS
- ☐ 5: Integrada en SGSI, revisión continua, benchmarking sectorial
- **Observaciones:** ____

P1.1.2 ¿La junta directiva / consejo de administración recibe reportes de ciberseguridad regularmente (auditoría, riesgo, incidentes)?

- ☐ 1: No
- ☐ 2: Informalmente, ocasionalmente
- ☐ 3: Trimestralmente
- ☐ 4: Bimestralmente + KRIs (Key Risk Indicators) en dashboard
- ☐ 5: Mensualmente + análisis predictivo integrado
- **Observaciones:** ____

P1.1.3 ¿Existe designación formal de rol "Responsable de Seguridad" (CISO, RSEG) con presupuesto y autoridad documentados?

- ☐ 1: No existe
- ☐ 2: Responsable designado, sin presupuesto propio
- ☐ 3: Designado + presupuesto anual
- ☐ 4: CISO con presupuesto, autoridad en decisiones críticas
- ☐ 5: CISO + Comité seguridad multidisciplinar, autoridad ejecutiva
- **Observaciones:** ____

P1.1.4 ¿La organización tiene un Plan Estratégico de Ciberseguridad alineado con objetivos de negocio (3-5 años)?

- ☐ 1: No existe
- ☐ 2: Plan anual básico
- ☐ 3: Plan multianual documentado
- ☐ 4: Plan con KPIs y OKRs de seguridad cuantificados
- ☐ 5: Plan dinámico, revisión trimestral, ajuste predictivo
- **Observaciones:** ____

1.2 Cumplimiento Normativo

P1.2.1 ¿La organización ha identificado y documentado sus obligaciones regulatorias aplicables (ENS, NIS2, ISO 27001, RGPD, LOPD-GDD, sector-específicas)?

- ☐ 1: No
- ☐ 2: Identificadas parcialmente
- ☐ 3: Identificadas y documentadas
- ☐ 4: Documentadas + mapeo a controles internos
- ☐ 5: Mapeo integrado + auditoría trimestral cumplimiento
- **Observaciones:** ____

P1.2.2 ¿La organización se clasifica como entidad NIS2 (Esencial, Importante, o No aplicable)?

- ☐ No aplica (verificar si correcto)
- ☐ Entidad Importante (auditoría voluntaria recomendada)
- ☐ Entidad Esencial (auditoría obligatoria cada 24 meses)
- ☐ Aún no clasificada (acción: contactar CCN-CERT antes Q2 2025)
- **Observaciones:** ____

P1.2.3 ¿Existe plan de acción formal para cumplimiento NIS2 (si aplica) con hitos y responsables?

- ☐ 1: No existe
- ☐ 2: Plan en borrador
- ☐ 3: Plan aprobado, implementación iniciada
- ☐ 4: Plan ejecutándose, seguimiento 2×/trimestre
- ☐ 5: Plan en fase final, auditoría externa ya contratada
- **Observaciones:** ____

BLOQUE 2: GESTIÓN DE RIESGOS (MAGERIT MAR)

2.1 Tarea MAR.1: Caracterización de Activos

P2.1.1 ¿Existe inventario formalizado de activos críticos (información, servicios, hardware, software, personal, instalaciones)?

- ☐ 1: No existe
- ☐ 2: Inventario parcial, desactualizado (>6 meses)
- ☐ 3: Inventario actualizado semestralmente
- ☐ 4: Inventario en herramienta dedicada, actualización trimestral
- ☐ 5: CMDB integrada, actualización continua, correlación dependencias automática
- **Observaciones:** ____

P2.1.2 ¿Se ha asignado valoración de impacto (escala 0-100% o BAJO/MEDIO/ALTO) a cada activo crítico en dimensiones de seguridad (C, I, D, A, T)?

- ☐ 1: No
- ☐ 2: Valoración ad hoc, inconsistente
- ☐ 3: Valoración documentada, revisión anual
- ☐ 4: Valoración formalizada por perfil (Admin/Operación/Ataque), auditada
- ☐ 5: Valoración dinámica + Montecarlo simulación de impacto acumulado
- **Observaciones:** ____

P2.1.3 ¿Se han identificado y documentado dependencias entre activos (cascadas de valor, impacto repercutido)?

- ☐ 1: No
- ☐ 2: Identificadas parcialmente, documentación informal
- ☐ 3: Mapeadas en documento control, revisión anual
- ☐ 4: Modeladas en herramienta (PILAR, Qualys, Archer), análisis trimestral
- ☐ 5: Grafo dinámico de dependencias, análisis predictivo de fallo cascada
- **Observaciones:** ____

2.2 Tarea MAR.2: Caracterización de Amenazas

P2.2.1 ¿Se ha realizado análisis formal de amenazas (STRIDE, CAPEC, sector-específicas) a nivel de activo crítico?

- ☐ 1: No
- ☐ 2: Análisis informal, sin documentación estructurada

- ☐ 3: Análisis documentado anualmente
- ☐ 4: Análisis trimestral, correlación con threat intelligence (MITRE ATT&CK)
- ☐ 5: Análisis dinámico, integración feeds geopolítica (APT targeting región)
- **Observaciones:** ____

P2.2.2 ¿Se ha estimado frecuencia/probabilidad anual (ARO) de cada amenaza significativa basada en datos históricos, benchmarking o threat intelligence?

- ☐ 1: No
- ☐ 2: Estimación cualitativa subjetiva
- ☐ 3: Estimación basada en histórico interno (últimos 3 años)
- ☐ 4: Estimación cuantitativa: frecuencia histórica + benchmarking sector
- ☐ 5: Probabilidad dinámica: ML-based, feed INCIBE, contexto geopolítico
- **Observaciones:** ____

P2.2.3 ¿Se ha caracterizado degradación potencial (% pérdida valor por amenaza) por activo y dimensión de seguridad?

- ☐ 1: No
- ☐ 2: Estimación ad hoc, sin criterios consistentes
- ☐ 3: Degradación documentada, escala 0-100%
- ☐ 4: Degradación validada por SME, análisis escenario base/pesimista
- ☐ 5: Degradación probabilística (Montecarlo), impacto primario+secundario (€)
- **Observaciones:** ____

2.3 Tarea MAR.3: Caracterización de Salvaguardas

P2.3.1 ¿Existe inventario formal de salvaguardas implementadas (preventivas, disuasorias, detectivas, correctivas) mapeadas a amenazas críticas?

- ☐ 1: No existe
- ☐ 2: Inventario informal, cobertura incierta
- ☐ 3: Inventario documentado, cobertura validada anualmente
- ☐ 4: Inventario en CMDB + Declaración Aplicabilidad (DA) formal
- ☐ 5: DA integrada en SGSI ISO 27001, auditoría trimestral cobertura
- **Observaciones:** ____

P2.3.2 ¿Se ha evaluado la madurez/eficacia de cada salvaguarda significativa (escala L0-L5 CMM o 0-100%)?

- ☐ 1: No
- ☐ 2: Evaluación cualitativa ad hoc
- ☐ 3: Evaluación documentada, escala L0-L5
- ☐ 4: Evaluación formal por auditor externo, certificación (ISO, CCN)
- ☐ 5: Evaluación continua (SIEM + UEBA), predicción degradación
- **Observaciones:** ____

P2.3.3 ¿Se han identificado insuficiencias de salvaguardas (gap analysis) y priorizado por riesgo residual?

- ☐ 1: No
- ☐ 2: Identificadas informalmente, sin priorización
- ☐ 3: Informe de insuficiencias anual, priorización básica
- ☐ 4: Informe trimestral, priorización por ALE/ROI, plan de remediación
- ☐ 5: Gap analysis dinámico, priorización predictiva, automática reasignación
- **Observaciones:** _____

2.4 Tarea MAR.4: Estimación de Riesgo Residual

P2.4.1 ¿Se calcula el riesgo residual (impacto residual $\times$ frecuencia) por activo y se reporta en formato estandarizado (mapa de calor, matriz riesgo)?

- ☐ 1: No existe
- ☐ 2: Cálculo ad hoc, sin formalización
- ☐ 3: Cálculo documentado anualmente, matriz riesgo 3 $\times$ 3
- ☐ 4: Cálculo trimestral, matriz 5 $\times$ 5, reportado a Junta
- ☐ 5: Cálculo continuo (SIEM), actualizaciones semanales, score de riesgo dinámico
- **Observaciones:** _____

P2.4.2 ¿Se realiza análisis de impacto acumulado/repercutido (cascadas de riesgo entre activos interdependientes)?

- ☐ 1: No
- ☐ 2: Análisis conceptual, sin modelado
- ☐ 3: Análisis documentado en casos críticos
- ☐ 4: Análisis formalizado, herramienta (PILAR), revisión trimestral
- ☐ 5: Simulación dinámica cascadas, Montecarlo impacto negocio total
- **Observaciones:** _____

P2.4.3 ¿Existen decisiones de tratamiento de riesgo documentadas (mitigar, transferir, compartir, aceptar/financiar) con justificación y propietario?

- ☐ 1: No
- ☐ 2: Decisiones informales, sin documentación
- ☐ 3: Decisiones documentadas, aprobadas CISO
- ☐ 4: Decisiones formalizadas, registro de cambios, auditoría trimestral
- ☐ 5: Decisiones dinámicas, revaluación automática per evento/cambio sistemas
- **Observaciones:** _____

BLOQUE 3: INDICADORES Y MÉTRICAS DE CIBERSEGURIDAD

3.1 Marco Indicadores (GQM + NIST CSF + 46 INCIBE)

P3.1.1 ¿Existe marco formal de indicadores (KPIs, KRIs) de ciberseguridad alineado con NIST CSF (Identify, Protect, Detect, Respond, Recover)?

- ☐ 1: No existe

- ☐ 2: KPIs informales, sin estructura
- ☐ 3: KPIs documentados por función NIST, revisión anual
- ☐ 4: KPIs + KRIs integrados en dashboard, reportes mensuales
- ☐ 5: Marco GQM formalizado (Goals – Questions – Metrics), análisis predictivo
- **Observaciones:** ____

P3.1.2 ¿Se reportan regularmente métricas de madurez por dominio (Identify 68%, Protect 63%, Detect 64%, Respond 55%, Recover 53%, benchmark nacional)?

- ☐ 1: No se reportan
- ☐ 2: Reportes ad hoc, sin comparativa benchmarking
- ☐ 3: Reportes anuales, comparativa vs. estándar sectorial
- ☐ 4: Reportes trimestrales, benchmarking sectorial + top5 competidores
- ☐ 5: Reportes continuos, ML-based trend prediction, % mejora estimada
- **Observaciones:** ____

P3.1.3 ¿Se utilizan las 46 métricas INCIBE de ciberresiliencia (9 dominios: Gobernanza, Identificación, Protección, Detección, Respuesta, Recuperación, Análisis, Mejora, Tecnología) en evaluación anual?

- ☐ 1: Desconocidas / No aplicables
- ☐ 2: Conocidas, no aplicadas formalmente
- ☐ 3: Aplicadas en evaluación anual, auto-scoring
- ☐ 4: Aplicadas semestralmente, auditoría externa bienal
- ☐ 5: Integradas en SIEM continuo + auditoría anual externo
- **Observaciones:** ____

3.2 Cuantificación Financiera (FAIR/ALE)

P3.2.1 ¿Se cuantifica el riesgo cibernético en términos financieros (ALE, ROI, impacto negocio) utilizando metodología FAIR u similar?

- ☐ 1: No se cuantifica
- ☐ 2: Estimaciones cualitativas, sin rigor
- ☐ 3: ALE calculado para riesgos críticos, anualmente
- ☐ 4: ALE trimestral, incluye impacto primario + secundario (regulación, reputación)
- ☐ 5: Cuantificación continua, Montecarlo simulación, stress-testing escenarios
- **Observaciones:** ____

P3.2.2 ¿Se realiza análisis ROI (retorno sobre inversión) para decisiones de gasto en seguridad, justificando salvaguardas vs. riesgo residual?

- ☐ 1: No existe
- ☐ 2: Análisis ocasional, sin metodología formalizada
- ☐ 3: ROI calculado para proyectos >€50K
- ☐ 4: ROI estándar para todo proyecto, payback period <24 meses
- ☐ 5: Análisis dinámico ROI, reoptimización mensual presupuesto vs. riesgos
- **Observaciones:** ____

P3.2.3 ¿Se comunica a la Junta Directiva el "riesgo residual no mitigado" en términos de € impacto potencial anual?

- ☐ 1: No se comunica
- ☐ 2: Comunicación informal, estimaciones vagas
- ☐ 3: Reporte anual con cuantificación riesgo residual
- ☐ 4: Reporte trimestral, escenarios optimista/pesimista/base
- ☐ 5: Dashboard ejecutivo continuo, riesgo residual vs. tolerance línea
- **Observaciones:** _____

3.3 Monitoreo de Indicadores

P3.3.1 ¿Se monitorean indicadores de cobertura de salvaguardas (% de activos críticos con control X implementado)?

- ☐ 1: No
- ☐ 2: Monitoreo manual, trimestral
- ☐ 3: Reportes automáticos mensuales
- ☐ 4: Monitoreo semanal, alertas de desviaciones >5%
- ☐ 5: Monitoreo continuo, predicción drift, auto-remediación
- **Observaciones:** _____

P3.3.2 ¿Se calculan y reportan métricas de eficiencia seguridad (horas seguridad/1000 usuarios, cost per risk unit, incidents/año trending)?

- ☐ 1: No
- ☐ 2: Cálculo ocasional
- ☐ 3: Reporte anual de eficiencia
- ☐ 4: Reporte trimestral, comparativa vs. benchmark
- ☐ 5: Métricas en tiempo real, análisis causal (eventos → métricas)
- **Observaciones:** _____

BLOQUE 4: VULNERABILIDADES Y PRUEBAS DE PENETRACIÓN

4.1 Gestión de Vulnerabilidades

P4.1.1 ¿Existe proceso formalizado de identificación, evaluación y gestión de vulnerabilidades (CVSS, EPSS)?

- ☐ 1: Ad hoc, sin proceso documentado
- ☐ 2: Proceso básico, evaluación manual
- ☐ 3: Proceso documentado, herramienta (Qualys, Tenable), escaneos mensuales
- ☐ 4: Proceso formal, escaneos semanales, CVSS + EPSS scoring
- ☐ 5: Evaluación continua, ML-based priorización (explotabilidad + contexto negocio)
- **Observaciones:** _____

P4.1.2 ¿Cuál es el SLA promedio de remediación de vulnerabilidades críticas (CVSS 9.0-10.0)?

- ☐ SLA no definido
- ☐ >30 días

- ☐ 15-30 días
- ☐ 7-14 días (aligned ENS/NIS2 recommend)
- ☐ <7 días (L5: automatizado con aprobación)

- **Observaciones:** ____

P4.1.3 ¿Se realiza parcheo de sistemas operativos y aplicaciones de forma sistemática y regulada?

- ☐ 1: Ad hoc, sin calendario
- ☐ 2: Parcheo manual, retrasos comunes
- ☐ 3: Calendario mensual, pre-testing en ambiente separado
- ☐ 4: Parcheo semiautomático, críticos 48h, regulares 2 semanas
- ☐ 5: Parcheo automatizado con rollback, sin downtime

- **Observaciones:** ____

P4.1.4 ¿Se registra el % de sistemas "vulnerables críticos sin parchar" y se reporta como métrica KRI mensualmente?

- ☐ No se registra
- ☐ Se registra ocasionalmente
- ☐ Se registra mensualmente
- ☐ Se registra semanalmente, alertas >5%
- ☐ Se registra continuamente, puntuación de riesgo automática

- **Observaciones:** ____

4.2 Pruebas de Penetración

P4.2.1 ¿Se realizan pruebas de penetración (pentesting) regularmente siguiendo metodología estándar (OWASP, PTES, OSSTMM, NIST 800-115)?

- ☐ 1: Nunca
- ☐ 2: Ad hoc, cuando hay presupuesto
- ☐ 3: Anual (externa)
- ☐ 4: Semestral (externa) + trimestral (interna/red team)
- ☐ 5: Continuo (red team permanente, ejercicios mensales de escalada)

- **Observaciones:** ____

P4.2.2 ¿Cuál es el alcance de pentesting realizado?

- ☐ Ninguno
- ☐ Aplicaciones web únicamente
- ☐ Infraestructura externa (perimetral)
- ☐ Infraestructura externa + interna + wireless + física
- ☐ Todo lo anterior + OT/ICS (si aplica) + supply chain testing

- **Observaciones:** ____

P4.2.3 ¿Se tienen documentados y probados planes de remediación (y re-testing) para hallazgos críticos (CVSS 9+) de pentesting?

- ☐ No documentados

- ☐ Documentados ad hoc, sin seguimiento
- ☐ Documentados, plan de remediación anual
- ☐ Documentados, seguimiento trimestral, re-testing 90 días
- ☐ Documentados, seguimiento continuo, re-test automático post-remediación
- **Observaciones:** _____

P4.2.4 ¿Se realizan pruebas de seguridad física (acceso instalaciones, tailgating, RFID cloning)?

- ☐ No se realizan
- ☐ Ocasionalmente, sin metodología
- ☐ Anuales, OSSTMM "Seguridad Humana"
- ☐ Semestrales + ejercicios social engineering
- ☐ Continuas + autoevaluaciones mensuales empleados
- **Observaciones:** _____

4.3 Evaluación de Aplicaciones

P4.3.1 ¿Se realizan pruebas de seguridad en código (SAST/DAST) como parte del ciclo de desarrollo seguro?

- ☐ No se realizan
- ☐ Ocasionalmente, sin integración pipeline CI/CD
- ☐ Anuales, en aplicaciones críticas
- ☐ Mensuales, integradas en CI/CD
- ☐ Continuas (en cada commit), automated + manual review
- **Observaciones:** _____

P4.3.2 ¿Se mantiene un registro de vulnerabilidades identificadas vs. remedidas (trending)? ¿Cuál es el % promedio de resolución?

- ☐ No se mantiene
- ☐ Registro manual, % desconocido
- ☐ Registro anual, ~50% resolución
- ☐ Registro mensual, ~80% resolución
- ☐ Registro continuo, >95% resolución en 90 días
- **Observaciones:** _____

BLOQUE 5: SIEM Y MONITORIZACIÓN DE SEGURIDAD

5.1 Infraestructura SIEM

P5.1.1 ¿Existe solución SIEM (Security Information and Event Management) operativa en la organización?

- ☐ No existe
- ☐ Solución piloto / evaluación
- ☐ SIEM en producción <1 año
- ☐ SIEM operativo >1 año, >80% logs capturados

- ☐ SIEM maduro, >95% logs normalizados, XDR integrado

- **Observaciones:** ____

P5.1.2 ¿Qué % estimado de eventos/logs se capturan y centralizan en el SIEM?

- ☐ <25% (cobertura crítica)

- ☐ 25-50% (departamentos principales)

- ☐ 50-75% (mayoría sistemas)

- ☐ 75-90% (casi completo)

- ☐ >90% (cobertura integral)

- **Observaciones:** ____

P5.1.3 ¿Se cuenta con capacidad de escaneo activo y pasivo de red (asset discovery, vulnerabilidades)?

- ☐ No

- ☐ Escaneo pasivo únicamente

- ☐ Escaneo activo semanal

- ☐ Escaneo activo + pasivo continuo

- ☐ Escaneo continuo + machine learning detección anomalías

- **Observaciones:** ____

5.2 Reglas y Detección

P5.2.1 ¿Se han personalizado reglas de correlación en el SIEM para el entorno específico (reduciendo falsos positivos)?

- ☐ No, usando reglas por defecto

- ☐ Reglas por defecto + ajustes manuales ocasionales

- ☐ Reglas personalizadas documentadas, revisión semestral

- ☐ Reglas personalizadas, revisión trimestral + threat intelligence integration

- ☐ Reglas dinámicas, ML-based tuning automático, <10% false positive rate

- **Observaciones:** ____

P5.2.2 ¿Se implementa análisis de comportamiento de usuarios y entidades (UEBA) para detección de anomalías?

- ☐ No

- ☐ En evaluación

- ☐ UEBA básico, alertas manually reviewed

- ☐ UEBA con puntuación riesgo, investigación automática

- ☐ UEBA avanzado + peer group analysis + ML scoring

- **Observaciones:** ____

P5.2.3 ¿Se integran feeds de threat intelligence externo (MITRE ATT&CK, malware, APT, geolocalización) en reglas SIEM?

- ☐ No

- ☐ Manual, ocasionalmente

- ☐ Integración semanal

- ☐ Integración diaria, enriquecimiento de alertas
- ☐ Integración en tiempo real, contexto geopolítico/sectorial
- **Observaciones:** ____

5.3 Alertas y Respuesta

P5.3.1 ¿Cuál es el volumen promedio diario de alertas generadas por SIEM? ¿Cuántas son investigadas?

- ☐ >1000/día, <1% investigado (exceso ruido)
- ☐ 500-1000/día, 5% investigado
- ☐ 100-500/día, 20% investigado
- ☐ 50-100/día, >80% investigado
- ☐ <50/día, >95% investigado (precisión L5)
- **Observaciones:** ____

P5.3.2 ¿Se cuenta con playbooks de respuesta automatizada (SOAR: Security Orchestration, Automation & Response)?

- ☐ No
- ☐ Playbooks manuales documentados
- ☐ Algunos playbooks automatizados (creación tickets, notificaciones)
- ☐ Playbooks automáticos para >50% casos comunes
- ☐ Orquestación automática + aprobación + auto-remediación
- **Observaciones:** ____

P5.3.3 ¿Cuál es el tiempo promedio de detección a investigación inicial (Time to Detect)?

- ☐ >24 horas
- ☐ 12-24 horas
- ☐ 4-12 horas
- ☐ 1-4 horas
- ☐ <1 hora (automated)
- **Observaciones:** ____

5.4 Informes y Análisis

P5.4.1 ¿Se generan reportes automáticos de seguridad desde SIEM (diarios, semanales, mensuales, ejecutivos)?

- ☐ No
- ☐ Reportes manuales ocasionales
- ☐ Reporte semanal básico
- ☐ Reportes automáticos: diarios (SOC), mensuales (ejecutivo)
- ☐ Reportes continuos: dashboard en tiempo real + análisis predictivo
- **Observaciones:** ____

P5.4.2 ¿Se realiza análisis forense de incidentes significativos (post-mortem, root cause analysis, timelines)?

- ☐ Nunca

- ☐ Ocasionalmente, en incidentes críticos
- ☐ Análisis documentado de todos incidentes >CVSS 7
- ☐ Análisis formal de todos incidentes, lecciones aprendidas documentadas
- ☐ Análisis automático, correlación con histórico, ML pattern recognition
- **Observaciones:** ____

BLOQUE 6: CAPACITACIÓN Y CONCIENCIACIÓN EN SEGURIDAD

6.1 Programa de Formación

P6.1.1 ¿Existe programa formal de capacitación en seguridad para empleados con contenido documentado y calendario?

- ☐ No existe
- ☐ Capacitación ad hoc, sin plan
- ☐ Plan anual de capacitación, obligatoria 1×/año
- ☐ Plan semestral, 2 sesiones/año + formación roles específicos
- ☐ Programa continuo, módulos mensuales + roles específicos personalizados
- **Observaciones:** ____

P6.1.2 ¿Cuál es el % de empleados que completó capacitación obligatoria en seguridad en los últimos 12 meses?

- ☐ <25%
- ☐ 25-50%
- ☐ 50-75%
- ☐ 75-90%
- ☐ >95%
- **Observaciones:** ____

P6.1.3 ¿Se incluyen en la capacitación temas específicos: MAGERIT/MAR, ENS, NIS2, RGPD, respuesta incidentes, ingeniería social?

- ☐ Ninguno
- ☐ 1-2 temas
- ☐ 3-4 temas
- ☐ 5-6 temas (completo)
- ☐ 6+ temas + actualizaciones trimestrales por nuevas amenazas
- **Observaciones:** ____

P6.1.4 ¿Se realizan sesiones de capacitación específica para personal TI/Seguridad vs. usuarios finales?

- ☐ No, formación genérica
- ☐ Diferenciación básica
- ☐ 2 tracks: TI vs. usuarios
- ☐ 3+ tracks: ejecutivos, TI avanzado, operadores, usuarios
- ☐ Formación personalizada por rol + competencias L0-L5 CMM
- **Observaciones:** ____

6.2 Concienciación y Simulaciones

P6.2.1 ¿Se realizan campañas de simulación de phishing (fake emails) para medir concienciación?

- ☐ No
- ☐ Ocasionalmente (1×/año)
- ☐ Mensualmente
- ☐ Quincenalmente con refuerzo educativo inmediato
- ☐ Semanales + ML-based targeting según perfil riesgo
- **Observaciones:** _____

P6.2.2 ¿Cuál es la tasa promedio de clics en emails de phishing simulado? ¿Se comunica públicamente?

- ☐ >30% (debilidad crítica, sin reportar)
- ☐ 20-30% (comunicación interna)
- ☐ 10-20% (con comparativa benchmarking)
- ☐ 5-10% (buena madurez)
- ☐ <5% (excelente, con trending mejora)
- **Observaciones:** _____

P6.2.3 ¿Se han implementado campañas de sensibilización adicionales (newsletters, posters, eventos)?

- ☐ No
- ☐ Ocasionalmente, sin plan
- ☐ Calendario anual de campaigns
- ☐ Campaigns mensuales + eventos anuales (seguridad awareness day)
- ☐ Campaigns continuas + gamificación + reconocimiento empleados
- **Observaciones:** _____

6.3 Métricas de Efectividad

P6.3.1 ¿Se miden métricas de efectividad de formación (pre/post evaluación, test de conocimientos, cambios comportamiento)?

- ☐ No se miden
- ☐ Medición ocasional, sin consistencia
- ☐ Test post-formación, documentado
- ☐ Pre + post evaluación, comparativa conocimientos adquiridos
- ☐ Evaluación continua + análisis causal (formación – reducción incidentes)
- **Observaciones:** _____

P6.3.2 ¿Se ha observado reducción en tasas de incidentes relacionados con error humano tras implementar programa de capacitación?

- ☐ No (o no se mide)
- ☐ Reducción leve (<10%)
- ☐ Reducción moderada (10-25%)
- ☐ Reducción significativa (25-50%)
- ☐ Reducción mayor (>50%) + tendencia sostenida
- **Observaciones:** _____

P6.3.3 ¿Se reportan anualmente a la Junta Directiva: tasa finalización capacitación, phishing rate, y ROI inversión concienciación?

- ☐ No
- ☐ Informalmente
- ☐ Reporte anual básico
- ☐ Reporte trimestral con métricas cuantificadas
- ☐ Dashboard ejecutivo continuo con tendencias y correlaciones
- **Observaciones:** ____

BLOQUE 7: RESILIENCIA Y CONTINUIDAD DE NEGOCIO

7.1 Backup y Recuperación

P7.1.1 ¿Existe política formal de backup documentada con RTO y RPO definidos por activo crítico?

- ☐ No existe
- ☐ Política ad hoc, RTO/RPO desconocidos
- ☐ Política documentada, RTO/RPO genéricos
- ☐ Política por servicio crítico, RTO <4h, RPO <1h
- ☐ Política granular, RTO <30min, RPO <15min sistemas críticos
- **Observaciones:** ____

P7.1.2 ¿Cuál es la frecuencia de backup para sistemas críticos?

- ☐ Semanal o menos frecuente
- ☐ Diario
- ☐ 2-4 veces/día
- ☐ Horario
- ☐ Continuo (replicación automática)
- **Observaciones:** ____

P7.1.3 ¿Se realizan pruebas de restauración (restore tests) de backups regularmente?

- ☐ Nunca
- ☐ Ocasionalmente (anual)
- ☐ Semestral
- ☐ Trimestral
- ☐ Mensual (simulacro completo)
- **Observaciones:** ____

P7.1.4 ¿Los backups se almacenan segregados (offline, encriptados, geográficamente dispersos)?

- ☐ No (backups en mismo datacenter)
- ☐ Parcialmente segregados
- ☐ Offline + encriptados, ubicación única
- ☐ Offline + encriptados + 2 ubicaciones geográficas
- ☐ 3+ ubicaciones + encriptación post-cuántica ready + immutable
- **Observaciones:** ____

7.2 Plan de Recuperación ante Desastres

P7.2.1 ¿Existe Plan de Recuperación ante Desastres (DRP) o Plan de Continuidad de Negocio (BCP) formalizado y documentado?

- ☐ No existe
- ☐ Plan en borrador / informal
- ☐ Plan documentado, no probado
- ☐ Plan probado anualmente (simulacro)
- ☐ Plan probado semestralmente, versiones para cada escenario crítico
- **Observaciones:** _____

P7.2.2 ¿Se han identificado Funciones Críticas de Negocio y Servicios Esenciales con prioridad de recuperación?

- ☐ No
- ☐ Identificadas informalmente
- ☐ Documentadas, lista de 5-10 críticos
- ☐ Documentadas con RTO/RPO por función + dependencias
- ☐ Identificadas + monitoreadas continuamente + matriz de cascadas
- **Observaciones:** _____

P7.2.3 ¿Se cuenta con sitio de recuperación alternativo (segunda ubicación, cloud backup, DR site)?

- ☐ No (single point of failure)
- ☐ En evaluación
- ☐ Sitio alternativo, recuperación manual
- ☐ Sitio alternativo con replicación automática, failover manual
- ☐ Failover automático, RTO <30 minutos, sin pérdida datos
- **Observaciones:** _____

7.3 Resiliencia Infraestructura

P7.3.1 ¿Se cuenta con redundancia en componentes críticos (servidores, almacenamiento, conectividad, energía)?

- ☐ No redundancia (single points of failure)
- ☐ Redundancia parcial (algunos componentes)
- ☐ Redundancia N+1 sistemas críticos
- ☐ Redundancia N+2 + balanceo carga
- ☐ Redundancia N+2+ + multi-zona disponibilidad + circuitos independientes
- **Observaciones:** _____

P7.3.2 ¿Se ha realizado análisis de impacto empresarial (BIA) identificando daño por cada hora de downtime?

- ☐ No existe
- ☐ Análisis conceptual, sin cuantificación
- ☐ BIA documentado, cuantificación genérica
- ☐ BIA por servicio crítico, daño/hora cuantificado (€)

- ☐ BIA dinámico + análisis escenario cascada + insurance integration

- **Observaciones:** ____

7.4 Pruebas de Resiliencia

P7.4.1 ¿Se realizan "chaos engineering" / "disaster recovery drills" (simulacros de fallo controlado)?

- ☐ Nunca

- ☐ Ocasionalmente (cada 2-3 años)

- ☐ Anual

- ☐ Semestral

- ☐ Trimestral + continuo (inyección de fallos automática)

- **Observaciones:** ____

P7.4.2 ¿Se cumple regularmente los RTO/RPO objetivos en ejercicios de recuperación?

- ☐ No se prueba / Incumplimiento >50%

- ☐ Cumplimiento <50%

- ☐ Cumplimiento 50-75%

- ☐ Cumplimiento 75-95%

- ☐ Cumplimiento >95% + margen de seguridad

- **Observaciones:** ____

P7.4.3 ¿Se ha realizado test de "ransomware recovery" (simulación cifrado datos, recuperación desde backup limpio)?

- ☐ No

- ☐ En teoría, no probado

- ☐ Test anual

- ☐ Test semestral + procedimiento documentado

- ☐ Test trimestral + automatización respuesta + seguros ciber

- **Observaciones:** ____

BLOQUE 8: CUMPLIMIENTO NORMATIVO (ENS + NIS2)

8.1 Evaluación ENS

P8.1.1 ¿Se ha realizado auditoría formal ENS (Esquema Nacional de Seguridad, RD 311/2022) de la organización?

- ☐ Nunca

- ☐ Auto-evaluación informal

- ☐ Auto-evaluación documentada (CMM L0-L5)

- ☐ Auditoría externa (anual, MEDIA o ALTA)

- ☐ Auditoría externa + seguimiento trimestral + mejora continua

- **Observaciones:** ____

P8.1.2 ¿Cuál es la categoría ENS estimada de la organización (BÁSICA, MEDIA, ALTA)?

- ☐ No clasificada

- ☐ BÁSICA (bajo impacto)
- ☐ MEDIA (moderado)
- ☐ ALTA (infraestructura crítica)
- ☐ Perfil adaptado por sector (sanidad, energía, finanzas)
- **Observaciones:** _____

P8.1.3 ¿Se ha realizado Análisis de Riesgos MAGERIT MAR completo (4 tareas) para determinar categoría ENS?

- ☐ No
- ☐ Análisis parcial (1-2 tareas)
- ☐ Análisis completo (MAR.1-4), documentado
- ☐ Análisis anual, herramienta (PILAR), auditoría externa
- ☐ Análisis continuo, actualización automática por cambios, ML-based
- **Observaciones:** _____

8.2 Evaluación NIS2

P8.2.1 ¿Se ha realizado evaluación formal de aplicabilidad NIS2 (¿Esencial, Importante, No aplica)?

- ☐ No
- ☐ Evaluación interna informal
- ☐ Evaluación documentada (confirmada con CCN-CERT)
- ☐ Clasificación oficial recibida de autoridad (si Esencial)
- ☐ Evaluación continua, revalidada anualmente
- **Observaciones:** _____

P8.2.2 Si aplica NIS2 como Esencial: ¿Se cuenta con auditoría externa vigente (ISO 27001 o equivalente)?

- ☐ N/A
- ☐ No es esencial
- ☐ Sin auditoría vigente
- ☐ Auditoría vigente (expira >6 meses)
- ☐ Auditoría vigente + seguimiento externo planificado
- **Observaciones:** _____

P8.2.3 ¿Se ha documentado un plan de acción para cumplimiento de requisitos NIS2 específicos (seguridad de cadena suministro, criptografía, gestión incidentes 72h)?

- ☐ No
- ☐ Plan en borrador
- ☐ Plan aprobado, implementación iniciada
- ☐ Plan ejecutándose, >50% hitos completados
- ☐ Plan final, auditoría de conformidad programada
- **Observaciones:** _____

8.3 Requisitos Específicos NIS2

P8.3.1 ¿Se realiza gestión de incidentes de ciberseguridad con notificación a autoridades en <72 horas si impacto significativo?

- ☐ No (no se reporta)
- ☐ Reporte manual, >72h
- ☐ Procedimiento documentado, <72h procesamiento
- ☐ Reporte automático, <72h para incidentes significativos
- ☐ Reporte inmediato con coordinación autoridades pre-establecida
- **Observaciones:** _____

P8.3.2 ¿Se ha implementado policy de criptografía alineada con recomendaciones CCN (cifrado datos en reposo y en tránsito)?

- ☐ No
- ☐ Cifrado parcial, estándares débiles
- ☐ Cifrado AES-256 en reposo, TLS 1.2+ en tránsito
- ☐ Cifrado AES-256, TLS 1.3, algoritmos CCN-STIC
- ☐ Criptografía cuántica-ready, PQC evaluada para 2026
- **Observaciones:** _____

P8.3.3 ¿Se realiza auditoría de ciberseguridad de proveedores y supply chain (SBOM, evaluación riesgos software)?

- ☐ No
- ☐ Auditoría ad hoc
- ☐ Auditoría de proveedores críticos anual
- ☐ Auditoría requerida en contratos + SBOM obligatorio
- ☐ Auditoría trimestral + análisis vulnerabilidades supply chain
- **Observaciones:** _____

P8.3.4 ¿Se cuenta con política de "seguridad del diseño" (secure by design) y ciclo de desarrollo seguro (DevSecOps)?

- ☐ No existe
- ☐ Iniciativa piloto
- ☐ Política documentada, aplicación inconsistente
- ☐ Política implementada, code review + scanning automatizado
- ☐ DevSecOps maduro, security gates en cada fase CI/CD
- **Observaciones:** _____

8.4 Cumplimiento RGPD y Regulación Sectorial

P8.4.1 ¿Se realiza análisis de privacidad (DPIA) para procesamiento de datos personales significativo?

- ☐ No
- ☐ Ocasionalmente, documentación informal
- ☐ Análisis documentado, revisión anual
- ☐ DPIA formal, evaluación externa para >CVSS 7 riesgos

- ☐ DPIA continua, ML-based identificación nuevos riesgos privacidad

- **Observaciones:** ____

P8.4.2 ¿Se cuenta con Data Protection Officer (DPO) designado y accesible a autoridades?

- ☐ No existe

- ☐ DPO designado, rol parcial

- ☐ DPO dedicado, contacto publicado

- ☐ DPO + equipo privacidad, reportes trimestrales

- ☐ DPO integrado en CISO team, gobernanza unificada

- **Observaciones:** ____

BLOQUE 9: INCIDENTES Y RESPUESTA

9.1 Gestión de Incidentes

P9.1.1 ¿Existe plan formal de respuesta a incidentes (IRP) con procedimientos, roles y SLAs documentados?

- ☐ No existe

- ☐ Plan en borrador

- ☐ Plan documentado, no probado

- ☐ Plan probado anualmente, actualización post-incidente

- ☐ Plan versionado, pruebas trimestrales, mejora continua

- **Observaciones:** ____

P9.1.2 ¿Se cuenta con equipo de respuesta a incidentes (CSIRT, SOC) disponible 24/7 durante incidente?

- ☐ No

- ☐ Equipo disponible horario laboral

- ☐ Equipo on-call, disponibilidad 24/5

- ☐ SOC 24/7 o contratación MSSP

- ☐ SOC interno 24/7 + threat intelligence + hunting proactivo

- **Observaciones:** ____

P9.1.3 ¿Se registran, clasifican y reportan todos los incidentes de ciberseguridad (incluso menores)?

- ☐ No se registran

- ☐ Registro selectivo (solo críticos)

- ☐ Registro de todos incidentes, clasificación básica

- ☐ Registro + clasificación CVSS + análisis root cause

- ☐ Registro continuo + análisis automático + trending predictivo

- **Observaciones:** ____

9.2 Análisis y Aprendizaje

P9.2.1 ¿Se realiza análisis post-incidente formal (post-mortem) de incidentes significativos?

- ☐ Nunca

- ☐ Ocasionalmente

- ☐ Para incidentes CVSS >7, documentado
- ☐ Para todos incidentes >CVSS 4, lecciones aprendidas formalizadas
- ☐ Para todos incidentes, análisis automático + correlación histórica
- **Observaciones:** ____

P9.2.2 ¿Se comunican lecciones aprendidas a toda la organización (no solo seguridad)?

- ☐ No
- ☐ Comunicación interna (equipo seguridad)
- ☐ Comunicación a TI/operaciones
- ☐ Comunicación a toda la organización, newsletter mensual
- ☐ Comunicación + sesiones de aprendizaje + gamificación prevención
- **Observaciones:** ____

9.3 Estadísticas de Incidentes

P9.3.1 ¿Cuántos incidentes se han identificado/respondido en los últimos 12 meses?

- ☐ 0-5 (muy bajo, posible subregistro)
- ☐ 6-20
- ☐ 21-50
- ☐ 51-100
- ☐ >100 (maduro programa detección)
- **Observaciones:** ____

P9.3.2 ¿Cuál es el tiempo promedio de detección a contención (Time to Contain) de incidentes?

- ☐ >48 horas
- ☐ 24-48 horas
- ☐ 8-24 horas
- ☐ 2-8 horas
- ☐ <2 horas (automatizado)
- **Observaciones:** ____

P9.3.3 ¿Se ha padecido algún incidente con impacto significativo (datos comprometidos, downtime >1h, daño reputacional)?

- ☐ Sí, en últimos 12 meses
- ☐ Sí, 1-2 años atrás
- ☐ Sí, >2 años (lecciones aplicadas)
- ☐ No, histórico limpio
- ☐ No, + pruebas demostraron resiliencia
- **Observaciones:** ____

BLOQUE 10: MADUREZ GENERAL Y OBSERVACIONES FINALES

10.1 Auto-evaluación General

P10.1.1 ¿Cuál es su evaluación general de madurez de ciberseguridad?

- ☐ L1 Inicial (ad hoc, reactivo, no documentado)
- ☐ L2 Básico (documentado, inconsistente)
- ☐ L3 Repetible (procesado, consistente, medido)
- ☐ L4 Gestionado (optimización, mejora continua)
- ☐ L5 Optimizado (adaptativo, predictivo, benchmarking)

P10.1.2 ¿Cuál es su nivel de confianza en responder a estas preguntas (1-5)?

- ☐ 1 Bajo (muchas incógnitas)
- ☐ 2 Moderado (dudas en varias áreas)
- ☐ 3 Aceptable (claridad en mayoría)
- ☐ 4 Alto (información confiable)
- ☐ 5 Muy alto (datos verificados, auditoría)

10.2 Prioridades de Mejora

P10.2.1 ¿Cuáles son los 3 riesgos más críticos identificados?

1. _____
2. _____
3. _____

P10.2.2 ¿Cuáles son las 3 salvaguardas de mayor impacto a implementar en próximos 6 meses?

1. _____
2. _____
3. _____

10.3 Contexto Organizacional

P10.3.1 Sector de la organización:

- ☐ Público (Administración)
- ☐ Financiero / Seguros
- ☐ Salud
- ☐ Energía / Utilities
- ☐ Telecomunicaciones
- ☐ Transporte
- ☐ Educación
- ☐ Industrial / Manufactura
- ☐ Retail / Distribución
- ☐ Otro: _____

P10.3.2 Tamaño de la organización:

- ☐ <25 empleados (micro)

- ☐ 25-250 (pyme)
- ☐ 251-2.500 (empresa media)
- ☐ >2.500 (gran empresa)

P10.3.3 Observaciones finales / Contexto adicional:

AGRADECIMIENTO Y CONTACTO

Gracias por completar esta encuesta. Los datos se tratarán confidencialmente y se utilizarán para generar un informe diagnóstico personalizado.

Próximos pasos:

1. Análisis de respuestas (5-7 días laborales)
2. Informe ejecutivo con recomendaciones priorizadas
3. Sesión de feedback y plan de acción (opcional)

Contacto: [info@organizacion.es] | [CISO/Responsable Seguridad]

© 2026 Kit Encuesta MAGERIT-NIS2-ENS | Consorcio Ciberseguridad Datos y Estrategia
Documento confidencial. Prohibida distribución sin consentimiento.